

Proyecto 2 - Historia Clinica

Michael

Preguntas 3 y 4: usuarios, roles e interfaz

Entrega integrada | 9 de octubre de 2026

Modelo y reglas de negocio

Usuario y Rol son entidades relacionadas: cada usuario tiene un rol mediante ManyToOne y rol_id. Un rol puede ser asignado a varios usuarios. Usuario guarda username unico, passwordHash, activo y rol; Rol guarda codigo unico, nombre y activo.

GestionUsuariosService implementa creacion, consulta, edicion y activacion/desactivacion. Los controladores web y REST reutilizan este servicio; los repositorios no se usan directamente para saltarse reglas de negocio.

Las claves se almacenan con BCrypt y el hash no se devuelve en JSON. Se validan nombres de usuario de 3 a 50 caracteres, claves de al menos 10 caracteres y el limite de 72 bytes de BCrypt. Una clave vacia durante edicion conserva la anterior.

No se puede desactivar ni quitar el rol al ultimo administrador activo. La comprobacion usa bloqueo del rol administrador para reducir conflictos entre modificaciones simultaneas. Solo se asignan roles activos.

ADMINISTRADOR, MEDICO y RECEPCIONISTA son los codigos usados por la seguridad. Editar el nombre visible no cambia el codigo que determina los permisos. Desactivar un rol revoca el acceso de sus usuarios.

Interfaz y API para la exposicion

Las pantallas Thymeleaf /admin/usuarios y /admin/roles muestran formularios y listados. Permiten crear, editar y activar/desactivar. El formulario de usuarios selecciona un rol; los errores de validacion se muestran al usuario.

API: GET/POST /api/admin/usuarios; PUT /api/admin/usuarios/{id}; PATCH /api/admin/usuarios/{id}/estado. Los roles usan el mismo patron en /api/admin/roles. Los cambios de estado reciben activo.

Flujo: ingresar como administrador, abrir Roles, crear un rol ficticio, editar su nombre y alternar su estado. Abrir Usuarios, registrar un usuario ficticio, asignarle un rol activo, editarlo y alternar su estado. Mantener el administrador original.

Mostrar que el JSON no contiene passwordHash y que el medico recibe 403 en la administracion. La seguridad efectiva se explica en la parte de Jerry: ocultar el menu no sustituye al control de backend.

Antecedentes y alergias del proyecto anterior permanecen conectados a HistoriaClinica. Para demostrar otra relacion del modulo anterior, abrir el detalle de la historia y el enlace Ver antecedentes y alergias. Las ediciones verifican pertenencia a la historia.

Guion y preguntas del profesor

Guion: Mi parte de exposicion es la administracion de usuarios y roles y sus pantallas. Usuario referencia un Rol, el servicio aplica validaciones y BCrypt, y los formularios comparten la misma logica con la API. El sistema impide perder al ultimo administrador.

Este reparto no afirma que Michael sea autor de los nuevos commits de usuarios. La implementacion se completo con asistencia en la copia de Jery; Michael debe reproducir y comprender el flujo para defenderlo.

¿Por que no guardar la clave en texto? BCrypt crea un hash que permite comprobar la clave sin devolver ni almacenar su texto original.

¿Activacion es eliminacion? No. Conserva el usuario o rol y sus relaciones, pero bloquea su uso. Facilita mantener trazabilidad y reactivarlo.

¿Por que hay API y vistas? La API permite integraciones y pruebas; Thymeleaf ofrece una interfaz ejecutable en la misma aplicacion. Ambas pasan por Controller-Service-Repository.

Archivos: paquete com.tecsup.historiaclinica.usuarios; GestionUsuariosService, Usuario, Rol, sus repositorios y controladores; templates/usuarios.html y templates/roles.html.

Ejecucion y evidencia

Clonar <https://github.com/JeryBn/Evaluacion1Coello> y abrir el pom.xml de la raiz. Requisitos: Java 21, Maven y MySQL/MariaDB. No iniciar la carpeta antecedentes como otra aplicacion.

Crear la base historia_clinica e importar database/esquema-proyecto2.sql solamente en una base vacia. El esquema tiene 13 tablas y no publica registros ni claves. En una base existente, respaldar antes de actualizar.

Seguir el README: definir el perfil demo y las tres variables DEMO_ADMINISTRADOR_PASSWORD, DEMO_MEDICO_PASSWORD y DEMO_RECEPCIONISTA_PASSWORD. Iniciar Spring Boot e ingresar con admin, medico o recepcion. Las claves son definidas por quien instala y no se reemplazan si los usuarios ya existen.

Importar postman/Proyecto-2.postman_collection.json y configurar baseUrl y las claves de los tres usuarios. Ejecutar en orden. La coleccion obtiene CSRF antes de las operaciones de escritura y crea datos ficticios.

Resultado comprobado: 13 pruebas automatizadas exitosas. La coleccion ejecutada mediante Newman produjo 47 solicitudes HTTP y 30 aserciones sin fallos. Newman ejecuta el formato Postman; no debe confundirse con una ejecucion manual de su interfaz.

El reparto organiza la exposicion, no cambia la autoria de los commits. La implementacion restante se completo con asistencia de Codex en la copia de Jery. La guia utiliza indicaciones individuales: confirmar con el docente el formato de entrega del grupo.

Evidencia real: usuarios

Captura del entorno local integrado. Datos ficticios de demostracion; sin claves publicadas.

Inicio

Pacientes

Auditoria

Usuarios

Roles

Historias clínicas

Atención médica

← Atrás

Adelante →

admin

Cerrar sesion

Usuarios

Registrar usuario

Usuario

Contraseña

Rol

ADMINISTRADOR

Guardar usuario

Usuarios registrados

Usuario	Rol	Estado	Acciones
admin	ADMINISTRADOR	Activo	Editar Desactivar
medico	MEDICO	Activo	Editar Desactivar
repcion	RECEPCIONISTA	Activo	Editar Desactivar
demo.1791521183113	Rol editado	Activo	Editar Desactivar

Evidencia real: roles

Captura del entorno local integrado. Datos ficticios de demostracion; sin claves publicadas.

Inicio

Pacientes

Auditoria

Usuarios

Roles

Historias clínicas

Atención médica

← Atrás

Adelante →

admin

Cerrar sesion

Roles

Registrar rol

Codigo

Nombre

Guardar rol

Roles registrados

Codigo	Nombre	Estado	Acciones
ADMINISTRADOR	ADMINISTRADOR	Activo	Editar Desactivar
MEDICO	MEDICO	Activo	Editar Desactivar
RECEPCIONISTA	RECEPCIONISTA	Activo	Editar Desactivar
DEMO_1791521183113	Rol editado	Activo	Editar Desactivar